

Análisis de Ataque APT en Active Directory

Análisis forense y detección de amenazas persistentes avanzadas mediante técnicas MITRE ATT&CK, reglas Sigma y bastionado de infraestructura crítica.



Estructura del Análisis Blue Team

01

Escenario APT

Definición del vector de ataque dirigido a Active Directory y objetivos de detección.

02

Kill Chain

Diagrama de flujo cronológico de técnicas MITRE desde acceso inicial hasta exfiltración.

03

Técnicas MITRE

Identificación formal de TTPs utilizadas por el adversario con códigos específicos.

04

Evidencias IOC

Análisis forense con logs Sysmon, comandos Atomic Red Team y artefactos en disco.

05

Reglas Sigma

Traducción de IOCs a reglas portables compiladas para alertas en Splunk.

06

Bastionado

Propuestas de mitigación y hardening alineadas con ENS e ISO 27001.

* De la página 3 a la 5 del informe



Marco Normativo Aplicado



Esquema Nacional de Seguridad (ENS)

Real Decreto 311/2022 como referencia principal para protección de sistemas críticos.

- MP.SI.1: Registro de eventos
- OP.ACC.2/3: Gestión de accesos
- OP.EXP.1: Protección contra malware
- MP.COM.1: Seguridad en comunicaciones



ISO/IEC 27001:2022

Sistema de Gestión de Seguridad de la Información con controles específicos.

- A.12.4.1: Registro de eventos
- A.9.2.3/5: Gestión de accesos
- A.12.6.2: Protección contra malware
- A.13.1.1: Seguridad en comunicaciones

* Página 5 del informe

Kill Chain: Flujo Cronológico del Ataque APT



*Página 6 del informe

Técnicas MITRE ATT&CK Identificadas

T1566.001

Spearphishing con archivo adjunto malicioso que ejecuta payload mediante ingeniería social.

T1204.002

Ejecución por usuario engañado para activar código malicioso desde documento.

T1558.003

Kerberoasting: extracción de tickets TGS para descifrar contraseñas offline.

T1550.002

Pass the Hash: autenticación lateral usando hash NTLM sin contraseña clara.

T1136.002

Creación de cuenta de dominio como puerta trasera para acceso persistente.

T1547.001

Persistencia mediante claves Run del registro para ejecución automática.

T1041

Exfiltración de datos mediante canal C2 con codificación Base64.

T1027

Ofuscación de código para evadir detección antivirus y análisis.

*De la página 7 a la 8 del informe

Indicadores de Compromiso y Evidencias Técnicas por Fase de Ataque

Análisis detallado de artefactos digitales y correlación de eventos por técnica MITRE ATT&CK

* De la página 9 a la 33 del informe



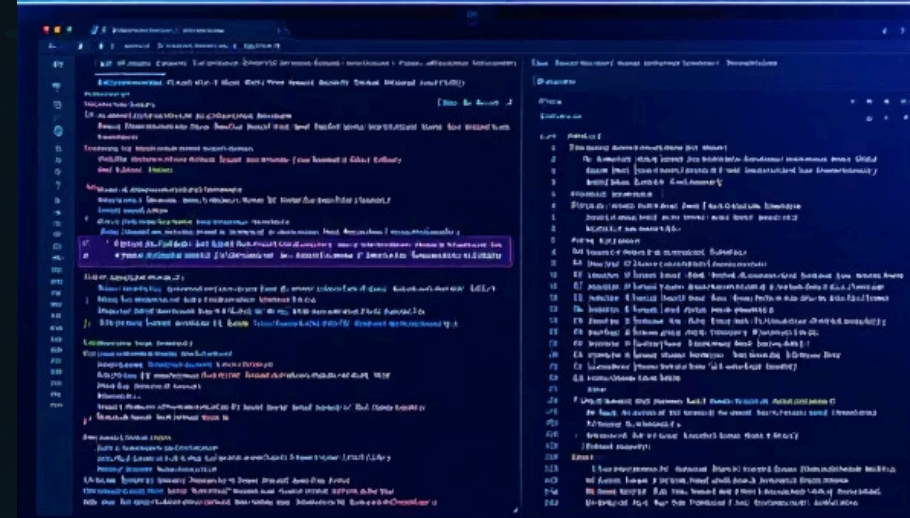
Spearphishing y Ejecución

1 T1566.001: Descarga del Adjunto
Archivo PhishingAttachment.xlsm creado en %TEMP% mediante Invoke-WebRequest. Sysmon Event ID 1 registra el proceso PowerShell con CommandLine completa.

2 T1204.002: Activación del Payload
Script click-fix.bat ejecutado por usuario. Logs correlacionados muestran cmd.exe lanzando PING.EXE y taskkill.exe para limpieza de procesos.

- ❑ **IOC Crítico:** Archivos .xlsm o .bat en carpetas temporales seguidos de procesos hijo sospechosos (cmd.exe, powershell.exe) son indicadores de alta fidelidad.

* De la página 9 a la 15 del informe



Kerberoasting y Pass the Hash

T1558.003: Kerberoasting

Múltiples eventos 4769 (solicitudes TGS) en Domain Controller con Ticket Options 0x40810000. Ejecución de Rubeus.exe detectada en Sysmon Event ID 1.

Umbral de detección: >10-15 solicitudes TGS/segundo por cuenta única.

T1550.002: Pass the Hash

Ejecución de mimikatz.exe con módulo sekurlsa::pth capturada en logs. CommandLine revela intención de movimiento lateral mediante hash NTLM.

Indicador: Herramientas de volcado de credenciales en memoria (LSASS).

* De la página 15 a la 23 del informe



Persistencia y Exfiltración



T1547.001

Modificación de claves Run mediante reg add. Sysmon Event ID 1 captura CommandLine con ruta *CurrentVersion\Run*.



T1136.002

Comando net localgroup Administrators detectado. Event ID 4720 registra creación de cuenta con privilegios elevados.



T1041

Invoke-WebRequest con método POST y datos codificados en Base64. DNS tunneling mediante Resolve-DnsName con subdominios largos.

- ❑ **Evasión T1027:** Ofuscación integrada en todas las fases mediante codificación Base64, renombrado de binarios y empaquetado de payloads.

* De la página 23 a la 33 del informe

Detección Operativa: Sigma y Splunk

01

Reglas Sigma (YAML)

Definición de lógica de detección portable centrada en `process_creation` de Sysmon con patrones de CommandLine específicos.

02

Compilación a SPL

Traducción mediante `sigma-cli` con pipeline `splunk_windows`. Optimización manual para búsqueda de texto libre en logs.

03

Alertas Activas

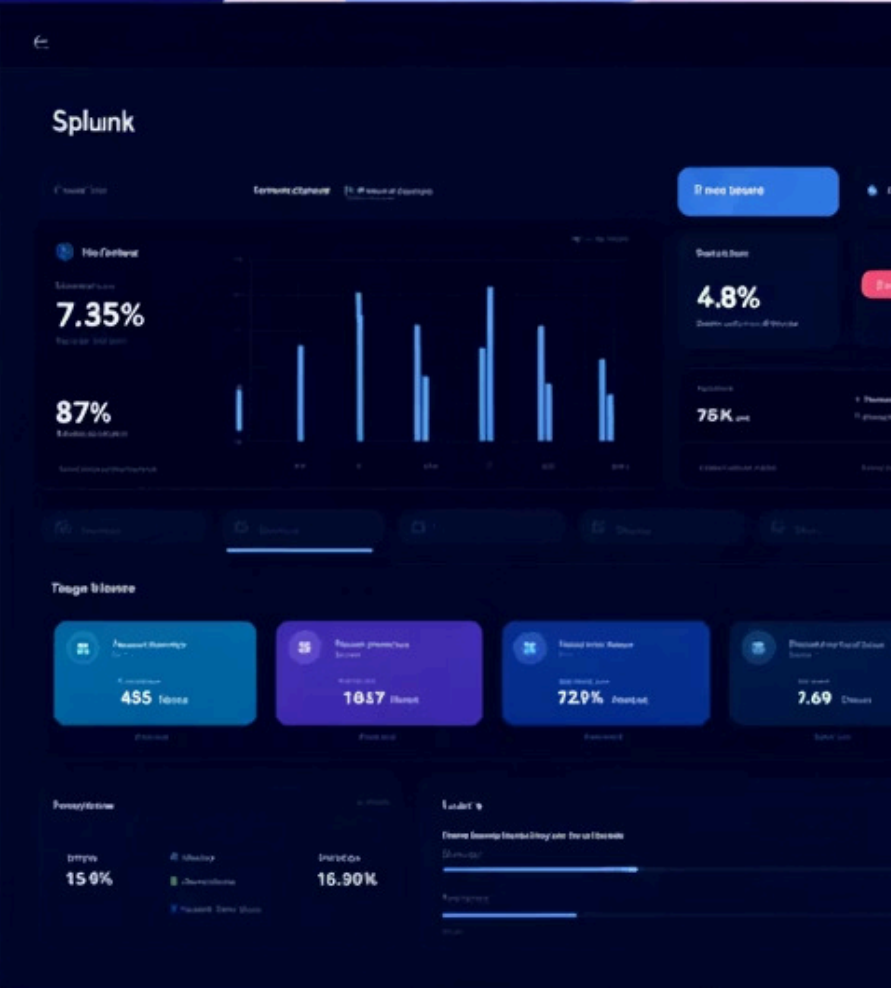
Configuración de triggers con condición "resultados > 0" y acción "Add to Triggered Alerts" para respuesta inmediata.

04

Verificación True Positive

Re-ejecución de técnicas de ataque confirmó aparición de alertas en panel de Splunk Enterprise.

* De la página 33 a la 38 del informe



Bastionado y Mitigación



Filtrado de Correo

Bloqueo de adjuntos de alto riesgo (.exe, .dll, .scr, macros). Implementación de DMARC, SPF y DKIM contra spoofing.



Reglas ASR

Attack Surface Reduction bloqueando procesos hijo desde Office y ejecución desde carpetas temporales.



Cuentas de Servicio

Contraseñas complejas 25+ caracteres, uso de gMSA y monitoreo de evento 4769 para detectar Kerberoasting.



Restricción NTLM

Priorización de Kerberos, parches CredSSP y limitación de NTLM a hosts estrictamente necesarios.



Mínimo Privilegio

Eliminación de derechos de administrador local, JIT Access para tareas elevadas y monitoreo de evento 4720.



Control de Tráfico

Filtros de proxy/firewall limitando puertos de salida e inspección SSL/TLS para detectar túneles cifrados.

* De la página 38 a la 40 del informe



Conclusiones

Este ejercicio nos ha permitido comprender de manera práctica cómo un ataque APT puede desarrollarse en un entorno de Active Directory y, sobre todo, cómo se puede documentar y defender con rigor técnico y normativo.

Comprensión Integral del Ataque

Se correlacionaron técnicas del adversario con evidencias reales y marcos como MITRE ATT&CK, Kill Chain y controles ENS/ISO 27001.

Detección Operativa Verificada

La traducción de IOCs a reglas Sigma y validación en Splunk con verdaderos positivos demuestra alertas útiles para el Blue Team.

Bastionado Integral

Medidas desde filtrado de correo y restricción NTLM hasta mínimo privilegio y gMSA, reforzando seguridad técnica, normativa y organizativa.

Mejora Continua

La ciberseguridad es un proceso continuo, donde formación, políticas DLP y segmentación son clave junto a las medidas técnicas.

* De la página 40 a la 41 del informe

¡Gracias!

La ciberseguridad es un viaje continuo de adaptación y mejora. La vigilancia constante y la proactividad son fundamentales para un futuro digital resiliente.